

**Topic: Security Audit and Strategy Report for
ABC Online Shop**

**Module: B108 Data Governance, Security and
Ethics**

Student Name: Adeyemi Jamiu Adegbenro

Student Id: GH1030456

Submission Date: 23rd March 2026

Final report

Table of Contents

- 1. Executive Summary**
- 2. Introduction**
- 3. Risk Assessment**
 - 3.1 Risk Identification and Classification**
 - 3.2 Risk Analysis**
 - 3.3 Security Assessment Findings**
- 4. Risk Treatment Plan**
 - 4.1 Immediate Actions**
 - 4.2 Medium-Term Actions**
 - 4.3 Long-Term Strategy**
- 5. Control Suggestions and Security Plan**
 - 5.1 Policies and Procedures**
 - 5.2 Technical Controls**
 - 5.3 Security Awareness and Culture**
- 6. Conclusion**
- 7. References**

1. Executive Summary.

ABC Online Shop is facing serious cyber- and operational risks from multiple instances of data breaches, account takeovers, third-party compromises, and system outages. This has revealed critical issues across the company's access controls, monitoring mechanisms, and overall governance.

This leads the organization to suffer financial loss, regulatory exposure, and many declining customers trust. Therefore, this document provides a detailed security audit and strategic response plan against recognised frameworks such as NIST and ISO/IEC 27001.

The risk assessment highlighted a concentration of high-priority risks, specifically in identity and access management, third-party integrations, and delayed threat detection. Such findings imply that the organisation's current security posture is largely reactive versus proactive. It is therefore an opportunity to formulate a comprehensive risk treatment plan in order to solve the challenges.

Now, the main actions should include multi-factor authentication (MFA), encryption, and zero-trust principles to decrease vulnerability towards critical threats. Medium-term strategies include using monitoring tools, such as Security Information and Event Management (SIEM) systems, and enhancing vendor risk management processes.

In a Longer term, the focus of recommendations is on infrastructure resilience, disaster recovery planning, and continuous security improvement. Moreover, a detailed security plan with integrated governance policies, technical controls, and employee awareness initiatives has also been created. This will involve applying an Information Security Management System (ISMS), improved encryption standards, real-time monitoring, and routine training sessions on security.

Finally, the suggested approach focuses cybersecurity efforts on business needs through risk reduction, regulatory compliance, and operational resilience. These actions could prove to be very effective in greatly reducing the organisation's risk exposure, restoring customer trust, and creating long-term sustainable growth for the company.

2. Introduction

The ABC Online Shop is a large e-commerce platform which operate in many countries, they also manage so many significant amounts of sensitive customer data, they also handle personal identification details and payment information of different clients and customers.

In line with the nature of its operations, the organisation must ensure high levels of information security, data governance, and operational resilience. However, recent incidents such as data breaches, account takeovers, compromises of third-party account, and system outages have exposed critical vulnerabilities at the organisation's infrastructure and governance.

So, this situation as resulted in financial losses, regulatory exposure, reputational damage, and lack of customer trust.

The increasing reliance on digital commerce platforms has made the company a target for online internet attacks, especially all those involving financial data and personal information (Behl and Behl, 2017). In this context, regulatory frameworks such as the General Data Protection Regulation (GDPR) as impose strict obligations on organisations to ensure the confidentiality, integrity, and availability of personal data (European Union, 2016).

So, I have prepared this report to conduct a structured security audit of ABC Online Shop. And its aims to identify key risks, check on existing vulnerabilities, and present a now and safe comprehensive security strategy that goes along with internationally recognised standards such as ISO/IEC 27001 (ISO, 2022) and the NIST cybersecurity frameworks (NIST, 2012).

Therefore, this report will be structured into four main sections: Risk assessment, Risk treatment plan, Security controls and strategy, and a final conclusion summarising key recommendations.

3. Risk Assessment

A risk assessment was conducted using the **NIST SP 800-30 framework**, which evaluates risks based on likelihood and impact (NIST, 2012). The findings reveal that ABC Online Shop faces multiple high-risk threats across its infrastructure, applications, and governance processes.

- 3.1. The identified risks make up:- data breaches, account takeovers, third-party compromises, system outages, and delayed threat detection. Therefore, risks were categorised using a **risk matrix approach**, allowing prioritisation of critical vulnerabilities, where likelihood and impact are categorised as low, medium, or high. Risks with both high likelihood and high impact were classified as critical risks, requiring immediate mitigation measures.

Table 1: Risk Assessment Matrix

Incident	Threat/Vulnerability	Likelihood	Impact	Risk Level	Priority	Key Impact Area	Recommended Control
Data Breaches	Weak access controls, unpatched applications	High	High (Financial/Legal)	High (Red)	1	Regulatory fines, data loss	MFA, encryption, patch management
Price Alterations	Insufficient input validation	Medium	High (Financial)	High (Red)	3	Revenue loss, fraud	WAF, secure coding practices

	and authorization						
Third-Party Compromise	Poor vendor risk management	High	High (Reputational/Legal)	High (Red)	2	Data leakage, reputational damage	Vendor risk framework, API security
Account Takeovers	Absence of MFA, weak passwords	High	High (Financial/Reputational)	High (Red)	1	Fraudulent transactions	MFA, identity monitoring
System Downtime	Lack of redundancy and DRP	Medium	High (Operational/Financial)	High (Amber)	4	Service disruption, revenue loss	Multi-region infrastructure, DRP
Delayed Detection	Lack of SIEM and monitoring tools	High	Medium (Financial)	High (Amber)	2	Prolonged attacks, unnoticed breaches	SIEM, real-time monitoring
Data Exposure (Phishing)	Lack of encryption (TLS) and user awareness	High	High (Legal)	High (Red)	1	Data interception, legal penalties	TLS encryption, user training
Inventory Disruptions	Lack of rate limiting and bot protection	Medium	Medium (Operational)	High (Amber)	5	Stock manipulation, delays	Bot management, rate limiting
Server Misconfigurations	Poor access control to backup systems	Medium	High (Legal)	High (Amber)	3	Data exposure, compliance failure	Configuration monitoring

Legal Ramifications	Cumulative non-compliance	High	High (Financial/Legal)	High (Red)	1	Fines, lawsuits	Compliance framework (GDPR, ISO)
----------------------------	---------------------------	------	------------------------	------------	---	-----------------	----------------------------------

*These analysis shows a concentration of **high-likelihood and high-impact risks**, particularly in areas relating to access control, monitoring, and third-party integration.*

The risk matrix highlights a clear concentration of high-risk vulnerabilities within access control, monitoring, and third-party integration domains. So this suggests that the organisation's security posture is heavily reactive rather than proactive. In particular, the repeated occurrence of similar incidents indicates a lack of continuous risk assessment and failure to implement preventive controls. Therefore, from a governance perspective, this reflects insufficient integration of security into strategic decision-making processes.

3.2. Key Risk Analysis

Most times the critical risk relates to **data breaches caused by weak access control mechanisms and unpatched systems**. This kind of breaches usually expose sensitive customer data and can lead to significant legal consequences under GDPR, including fines and compensation claims (European Union, 2016).

Another serious risk involves **customer account takeovers**, and its usually due to weak authentication mechanisms. The absence of multi-factor authentication significantly increases the likelihood of unauthorized access, leading to serious financial losses and business reputational damage.

Also, Third-party integrations also present a major high-risk area. With poor vendor risk management allows external systems to introduce vulnerabilities, as we have seen in the compromise of analytics tools. This highlights the importance of supply chain security, as emphasised in NIST guidelines (NIST, 2020).

Operational risks are evident in **system downtime caused by insufficient disaster recovery planning**. Without an adequate redundancy and backup systems, the company is unable to maintain service continuity, and this will result into revenue loss and customer dissatisfaction.

The company also demonstrates weaknesses in **threat detection capabilities**, as malicious activities remained undetected for an extended period of time. Effective monitoring systems such as SIEM are essential for identifying and responding to such threats in real time (NIST, 2018).

furthermore, **phishing attacks** have exposed weaknesses in securing data transmission and user awareness. These attacks compromise customer data and highlight the need for stronger encryption and frequent training programmes.

3.3. Lastly, **server misconfigurations and inventory manipulation attacks** also indicate poor internal controls and lack of automated security enforcement mechanisms.

Some Root Causes

The root causes of these vulnerabilities grouped into 3 categories:

- Lack of a structured **information security management system (ISMS)** (ISO, 2022)
- Insufficient **technical controls**, including encryption and access management
- Weak **governance and organisational processes**, particularly in vendor management and incident response

These systemic weaknesses must be addressed to improve the organisation's overall security appearance.

4. Risk Treatment Plan

The risk treatment plan is based on the **ISO 31000 risk management framework**, which point out strategies such as mitigation, avoidance, transfer, and acceptance (Peltier, 2016).

4.1. High-Priority Risk Mitigation (0–3 Months)

The most important and urgent risks include data breaches, account takeovers, and phishing attacks. These risks require immediate mitigation through the implementation of **multi-factor authentication (MFA)** and strong encryption protocols to avoid a very high risk

Encryption of data both in transit and at rest is essential to comply with GDPR requirements for data protection according to (European Union, 2016). Implementing TLS 1.3 and AES-256 encryption significantly reduces the risk of data interception.

4.2. Medium-Term Risk Mitigation (3–6 Months)

Medium-priority risks include third-party vulnerabilities and delayed in threat detection. To address issues like this, the organisation must implement a **Security Information and Event Management (SIEM) system**, which enhances visibility and enables real-time threat detection (NIST, 2018).

Furthermore, a formal **vendor risk management framework** should also be introduced, ensuring that all third-party providers comply with recognised standards protocol such as ISO 27001 (ISO, 2022).

4.1. Long-Term Risk Management

In this case to improve operational resilience, the organisation should adopt **high-availability infrastructure and disaster recovery mechanisms**. They include multi-region deployments, automated backups, and clearly defined recovery objectives.

Also, Cyber insurance may also be considered as a risk transfer strategy to reduce financial exposure resulting from cyber incidents.

Table 2: Risk Treatment Plan and Implementation Roadmap

Risk Priority	Treatment Strategy	Timeline	Responsible	Expected Outcome	Success Metrics
1 (Breaches, Takeovers, Phishing, Legal)	Implement Zero Trust architecture, MFA, and end-to-end encryption	0–3 months	CISO / IT Security	Significant reduction in unauthorized access and data breaches	Reduction in breach incidents; MFA adoption rate >90%
2 (Third-Party, Detection)	Establish Vendor Risk Management (SRM) framework and deploy SIEM system	3–6 months	Security Team	Improved visibility and control over third-party risks and faster threat detection	Mean Time to Detect (MTTD) < 24 hours
3 (Price Manipulation, Server Misconfigurations)	Deploy WAF and automated configuration monitoring (e.g., AWS Config)	1–3 months	DevOps	Prevention of application-layer attacks and misconfigurations	Reduction in application vulnerabilities and misconfig incidents
4 (System Downtime)	Implement multi-region architecture and Disaster Recovery Plan (RTO < 4 hours)	3–6 months	Infrastructure Team	Improved system availability and reduced service disruption	System uptime > 99.9%; recovery time within SLA
5 (Inventory Abuse)	Apply bot management tools and rate limiting (e.g., Cloudflare)	Ongoing	Operations Team	Reduced automated abuse and improved inventory stability	Reduction in bot traffic and abnormal order spikes

So here, the treatment plan demonstrates a prioritisation strategy based on both risk severity and operational feasibility. Immediate actions focus on high-impact vulnerabilities, while medium- and long-term strategies aim to strengthen organisational resilience. This phased approach ensures

that security improvements are both effective and sustainable, aligning technical implementation with business objectives.

5. Control Suggestions and Security Plan

A comprehensive security strategy must integrate **policy development, technical controls, and organisational awareness**.

5.1 Policies and Procedures

The organisation should off cos establish a **Data Governance Policy** aligned with ISO 27001 standards to ensure proper classification and handling of sensitive data (ISO, 2022).

An **Incident Response Plan (IRP)** should also be implemented based on some NIST guidelines to ensure swift detection and response to security incidents (NIST, 2018). Regular testing through simulation exercises is essential to maintain effectiveness.

Vendor management policies must require third parties also to comply with security standards and undergo regular audits.

5.2 Technical Controls

Access Management

The implementation of **Role-Based Access Control (RBAC)** and **multi-factor authentication** ensures that access to sensitive systems is restricted and monitored (NIST, 2020).

Encryption

Data encryption should also follow industry standards such as AES-256 for storage and also TLS for transmission, ensuring compliance with GDPR security requirements (European Union, 2016).

Monitoring and Detection

The deployment of **SIEM and Endpoint Detection and Response (EDR) systems** will also enable continuous monitoring and early detection of threats (NIST, 2018).

Web Application Security

A **Web Application Firewall (WAF)** must also be implemented to helps protect against common vulnerabilities such as SQL injection and cross-site scripting, aligning with PCI DSS requirements (PCI Security Standards Council, 2022).

Infrastructure Resilience

The organisation should also introduce **cloud-based redundancy and automated scaling** to ensure system availability during peak demand or during the time of system failures.

Table 3: Security Control Framework and Risk Alignment

Control Category	Recommendations	Standards Alignment	Risk Addressed	Expected Outcome
Access Management	Implement MFA across all user and admin accounts; enforce RBAC and Just-in-Time (JIT) access	ISO/IEC 27001 A.9; NIST SP 800-53	Account Takeovers, Data Breaches	Reduces unauthorized access risk and strengthens identity security
Encryption	Deploy TLS 1.3 for data in transit and AES-256 for data at rest using AWS KMS	GDPR Art.32; ISO 27001 A.10	Data Breaches, Phishing Attacks	Ensures confidentiality and regulatory compliance
Monitoring & Detection	Implement SIEM (Splunk/ELK), EDR solutions, and anomaly detection systems	NIST SP 800-53 AU-6; NIST SP 800-61	Delayed Threat Detection, Insider Threats	Enables real-time threat detection and faster incident response
Web/Application Security	Deploy WAF, implement rate limiting, and conduct OWASP Top 10 vulnerability testing	PCI DSS 6.6; OWASP Top 10	Price Manipulation, Injection Attacks	Protects applications from common cyberattacks
Infrastructure Resilience	Implement multi-region architecture, auto-scaling, and backup strategies with RPO < 1 hour	ISO 27001 A.17; DORA	System Downtime, Service Disruption	Ensures business continuity and reduces downtime impact
Third-Party Security	Enforce vendor risk assessments, API gateway security, sandboxing, and zero-trust architecture	NIST SP 800-161; ISO 27001 A.15	Third-Party Compromise	Reduces supply chain vulnerabilities

So, the security control framework above demonstrates a structured alignment between identified risks and mitigation strategies. By linking each control to specific vulnerabilities and expected outcomes, the organisation can ensure that security investments are both effective and measurable. This approach also supports regulatory compliance while enhancing operational resilience and customer trust.

5.3 Security Awareness and Culture

Also, human factors remain a major source of cybersecurity risk. So, it's required that Employees must undergo regular **security awareness training** to keep up to date, including phishing simulations and best practices for handling all sensitive data (ENISA, 2023).

And Performance metrics such as **Mean Time to Detect (MTTD)** and **Mean Time to Respond (MTTR)** should be always monitored to evaluate security effectiveness.

The effectiveness of the proposed security controls depends not only on technical implementation but it also on organisational adoption. Meaning that without proper governance, training, and continuous monitoring, even advanced security solutions may fail to deliver the intended outcomes. Therefore, a holistic approach integrating people, processes, and technology is essential.

6. Conclusion

So, in conclusion, the security assessment of the company ABC Online Shop highlights significant vulnerabilities across all its infrastructure, governance, and operational processes. The constant occurrence of cyber incidents shows the urgent need for a structured, fast and also comprehensive security strategy.

So, by implementing controls aligned with internationally recognised frameworks such as ISO 27001 and NIST, the organisation can surely reduce its risk exposure. so Immediate focus should be placed on strengthening access controls, improving monitoring capabilities, and securing sensitive data.

And in the long term, they should enhance governance structures, vendor management practices, and also employee awareness will be essential for maintaining resilience. By adopting these process, ABC Online Shop can surely restore customer trust, ensure regulatory compliance, and support sustainable business growth.

7. Reference

Behl, A. and Behl, K. (2017) Cybersecurity and Cyberwar: What Everyone Needs to Know. Oxford: Oxford University Press.

ENISA (2023) ENISA Threat Landscape 2023. Available at: <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2023> (Accessed: 22 March 2026).

Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (Text with EEA relevance) (2016) OJ L. Available at: <http://data.europa.eu/eli/reg/2016/679/oj> (Accessed: March 23, 2026).

ISO/IEC 27001:2022(en), Information security, cybersecurity and privacy protection — Information security management systems — Requirements (no date). Available at: <https://www.iso.org/obp/ui/en/#iso:std:iso-iec:27001:ed-3:v1:en> (Accessed: March 20, 2026).

ISO (2022) ISO/IEC 27001 Information Security Management. Available at: <https://www.iso.org/isoiec-27001-information-security.html> (Accessed: 23 March 2026).

ISO (2022) ISO/IEC 27002:2022 Information Security Controls. Geneva: International Organization for Standardization.

NIST (2012) Guide for Conducting Risk Assessments (SP 800-30 Rev.1). Available at: <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf> (Accessed: 19 March 2026).

NIST (2018) Computer Security Incident Handling Guide (SP 800-61 Rev.2). Available at: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf> (Accessed: 19 March 2026).

NIST (2020) Security and Privacy Controls for Information Systems and Organizations (SP 800-53 Rev.5). Gaithersburg: National Institute of Standards and Technology.

PCI Security Standards Council (2022) Payment Card Industry Data Security Standard (PCI DSS) Version 4.0.

PCI Security Standards Council (2022) PCI DSS v4.0. Available at: <https://www.pcisecuritystandards.org> (Accessed: 23 March 2026).

“Document Library” (no date) PCI Security Standards Council. Available at: https://www.pcisecuritystandards.org/document_library/ (Accessed: March 23, 2026).

AWS Security Documentation (no date). Available at: <https://docs.aws.amazon.com/security/> (Accessed: March 24, 2026).

AWS (2023) AWS Security Best Practices. Available at: <https://docs.aws.amazon.com/security> (Accessed: 23 March 2026).

NIST (2020) Zero Trust Architecture (SP 800-207). Available at: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf> (Accessed: 23 March 2026).

OWASP (2021) OWASP Top 10 Web Application Security Risks. Available at: <https://owasp.org/www-project-top-ten/> (Accessed: 23 March 2026).

Peltier, T.R. (2016) Information Security Risk Analysis. 3rd edition. Boca Raton: CRC Press.